Security Policy for [Hospital Name]

1. **Purpose** The purpose of this policy is to establish and maintain an effective framework for safeguarding patient and hospital data in compliance with the Health Insurance Portability and Accountability Act (HIPAA) of the United States and the Data Protection Act, 2012 (Act 843) of Ghana. It ensures that information security measures are implemented to protect the confidentiality, integrity, and availability of Protected Health Information (PHI) and Personally Identifiable Information (PII).

2. **Scope** This policy applies to all hospital personnel, including full-time and part-time staff, contractors, consultants, and third parties who access or handle patient information or hospital systems. It encompasses all physical and digital assets, including IT systems, network infrastructure, physical facilities, and patient records

Information Security Objective The objective of this policy is to ensure the consistent and effective implementation of information security controls that:

Protect patient data from unauthorized access, alteration, disclosure, or destruction;

Ensure compliance with HIPAA and Ghana's Data Protection Act, 2012 (Act 843);

Promote awareness and accountability among staff and stakeholders;

Facilitate the continuity of clinical and business operations through secure systems.

3. **Definitions**

PHI (Protected Health Information): Any information about health status, provision of health care, or payment that can be linked to an individual.

PII (Personally Identifiable Information): Any information that can identify an individual.

Data Subject: A living individual to whom personal data relates (per Ghana's DPA).

Controller & Processor: As defined under Ghana's Act 843.

4. **Governance and Roles**

Data Protection Officer (DPO): Ensures compliance with Ghana DPA and HIPAA.

IT Security Officer: Manages technical implementation of the policy.

Department Heads: Ensure team compliance and report incidents.

5. Data Classification

Confidential: Sensitive information that, if disclosed, could harm the organization or Individuals e.g., PHI, patient records

Internal: : Information intended for internal operations, not for public disclosure. e.g., operational procedures

Public: Information that can be freely shared with the public. e.g., hospital services overview Appropriate controls must be applied based on classification.

6. Access Control

Implement role-based access control (RBAC) to ensure that individuals have access only to information necessary for their role.

• Require multi-factor authentication (MFA) for access to critical systems.

• Conduct regular audits of user access rights.

• Enforce strong password policies, including regular password changes and complexity requirements

7. Data Handling & Storage

Encryption of PHI/PII at rest and in transit

Secure storage (on-premises or cloud) must comply with HIPAA encryption standards and DPA data localization if applicable

Prohibited to share PHI/PII via personal email or unsecured channels

8. Network and System Security

Firewalls and intrusion detection systems

Endpoint protection and regular patching

Regular vulnerability assessments and penetration tests

Secure Wi-Fi networks with guest access segregated

9. Physical Security

Restricted access to server rooms and data centers

Use of access badges, biometric controls, or security codes

Surveillance cameras in sensitive areas

Security personnel to monitor physical access points

Visitors must be escorted in restricted zones

10. Incident Response

Report incidents within 24 hours

Immediate containment and investigation

Notification of affected parties and Data Protection Commission (DPC) if breach occurs (per Ghana law)

Documentation and post-incident review

11. Employee Training and Awareness

Mandatory onboarding training on HIPAA and Ghana DPA

Annual refresher courses

Phishing simulations and awareness campaigns

12. Audit and Compliance

Regular audits to ensure compliance with HIPAA and DPA

Maintain logs for all data access and system activities

Documentation of policies, training, and audit results

13. Third-Party Management

Third parties must sign a Data Protection Agreement

Conduct due diligence and risk assessments

Third-party access must be monitored and audited

14. Retention and Disposal

Retain medical records per regulatory standards (e.g., 6 years under HIPAA)

Secure disposal methods: data wiping, shredding of physical records

Retention periods must comply with both HIPAA and Ghanaian legal requirements

15. Policy Enforcement

Violations may result in disciplinary action including termination or legal penalties

Policy reviewed annually or in response to regulatory changes